

B

Production Deployment & Technology Strategy

Ship lean, run it as an AI-operated bank, harden into a fraud-resistant, compliance-ready platform — grounded in the existing BankAI architecture.

BANKAI · CONFIDENTIAL — FOUNDER · JUNE 6, 2026

Strategic guidance only — not legal, financial, tax, or investment advice. Securities, money-transmission, and corporate-formation decisions must be reviewed by licensed counsel and a CPA before you act. Sections flagged “ see counsel” are where this matters most.

Contents

- 1. 1. Cloud — recommendation & cost envelope**
 - Stage 0 — lean launch (recommended now)
 - Stage 1 — consolidate on one hyperscaler (when traffic/compliance demands)
 - Rough cost envelope by scale
- 5. 2. Reference production architecture**
- 6. 3. The automation fabric — agents, MCP & skills to run the bank**
 - Two planes
 - Internal operating-agent catalog
 - Skills (Claude Agent SDK / MCP tools)
- 10. 4. Identity Vault — a Neo4j graph of users & associations**
- 11. 5. Fraud detection — best-of-breed, built on your orchestration engine**
- 12. 6. Constellation Network "Digital Evidence" — a later-phase evaluation**
- 13. 7. Mobile — launch iOS first**
- 14. 8. Marketing & go-to-market**
- 15. 9. Tech gaps to close (additive checklist)**
- 16. 10. Phased production roadmap (aligned to the compliance ramp)**

Production Deployment & Technology Strategy

How to ship BankAI to real users cheaply, run it as an AI-operated bank, and harden it into a fraud-resistant, compliance-ready platform — grounded in what's already built in the repo (Hedera settlement, the double-entry ledger, DID/VC + OID4VP + MCP, the risk-adaptive onboarding orchestrator, and the Phase 15 internal-agent-ops design).

How to read this. Recommendations are decisive and tagged **STAGE 0** (lean launch), **STAGE 1** (scale), or **STAGE 2** (licensed) so the tech rollout lines up with the three-phase compliance ramp in the *Corporate Structure* document. Costs are 2025–2026 planning estimates.

1 1. Cloud — recommendation & cost envelope

Verdict: don't put a hyperscaler bill on a pre-revenue product. **Start on a lean managed PaaS**, designed so the Stage-1 move to a single hyperscaler is a deploy-target change, not a rewrite.

Stage 0 — lean launch (recommended now)

The app is a stateless Node/TS API + Postgres + a few managed data services. Run it for tens of dollars a month:

Concern	Pick	Why / cost
API (Node/Express/TS)	Render or Fly.io	Git-push deploys, autoscale-to-cheap, private networking. ~\$7–25/mo
Postgres (prod <code>DATABASE_URL</code>)	Neon (serverless) or Supabase	Branching, scale-to-zero, backups. Free→\$20/mo. The code already abstracts SQLite↔Postgres
Graph (Identity Vault)	Neo4j Aura	Managed, free tier → serverless. \$0→\$65/mo
Cache / queue	Upstash Redis	Per-request pricing, ~\$0 at low volume
Secrets / KMS	Infisical or the PaaS secret store → cloud KMS at Stage 1	Closes the <code>private_key_hex</code> gap (see \$2)
Object storage	Cloudflare R2	No egress fees
CDN / WAF / DNS	Cloudflare	Free WAF + DDoS in front of everything

Stage-0 monthly burn: ~\$0–150 depending on traffic. That's the whole point — stay near zero until usage justifies more.

Stage 1 — consolidate on one hyperscaler (when traffic/compliance demands)

When you need VPC isolation, SOC 2 scope, managed Temporal/Conductor, and a data/ML platform, pick **one** cloud and commit:

	<i>(recommended default)</i>	<i>(pick if ML/graph dominates)</i>
Compliance ecosystem	Broadest; most BaaS banks, custodians, KYC vendors run here	Strong, slightly thinner fintech-partner set
Managed Postgres	RDS / Aurora	Cloud SQL / AlloyDB (excellent)
Containers/orchestration	EKS / ECS Fargate (host Temporal + Conductor)	GKE Autopilot (cheapest managed k8s)
ML / fraud	SageMaker	Vertex AI (best-in-class, cheaper to start)
KMS / HSM	KMS + CloudHSM (for the Hedera paymaster)	Cloud KMS + HSM
Cost at scale	Closeable with Savings Plans	Often 10–25% cheaper for data+ML

Recommendation: default to **AWS at Stage 1** — a money business benefits most from AWS's compliance breadth and the fact that your future partner banks/custodians (Corporate doc, Phase B) overwhelmingly live there, easing private-link integrations and vendor SOC 2 alignment. Choose **GCP** only if the fraud-ML and Identity-Vault graph workloads become the cost center — Vertex AI + AlloyDB are a genuinely better value for that shape. **Do not split across both.**

Rough cost envelope by scale

Users	Stage	Monthly infra (ballpark)
0–1k	Stage 0 (PaaS)	\$50–250
~1k–10k	Stage 0→1	\$300–1,500
~100k	Stage 1 (AWS/GCP, HA)	\$4k–12k + data/ML + SOC 2 tooling

2. Reference production architecture

The repo is already production-shaped (env-driven config that fails fast on insecure prod settings, Postgres-or-SQLite via `DATABASE_URL`, append-only ledger/audit triggers, RS256

token factory, pino + prom-client). Stage-1 wraps it in the standard hardening:

- **Network:** single VPC, private subnets for the DB/graph/Temporal; only the API + Cloudflare are public. mTLS / private link to partner-bank and custodian APIs at Phase B.
- **Secrets & keys — close the known gap.** Δ **priority.** The repo documents that Phase 5 stores `private_key_hex` server-side (Hedera paymaster + any server-held keys). Move these to **cloud KMS/HSM**: envelope-encrypt at rest, never log (pino redaction already strips secrets/tokens/VC/VP), and for the Hedera **treasury/paymaster** use an HSM-backed key and a **multisig** so no single server compromise drains funds. User keys remain on-device (Secure Enclave) — never regress that.
- **CI/CD:** GitHub Actions → typecheck + the full vitest suite (131 pass / 3 todo) + the **Playwright web E2E** (21 tests) as a required gate → deploy. Migrations run forward-only (already idempotent).
- **Observability (already emitting):** scrape the five prom-client counters (`ledger_post_total` , `vp_verify_total{result}` , `mcp_call_total{tool,result}` , `hedera_tx_total{result}` , `http_request_duration`) into **Grafana Cloud** (free tier) with alerts; ship pino logs to a retained store; add request-id tracing (already threaded).
- **Ledger integrity:** the append-only `ledger_entries` / `ledger_journals` / `audit_logs` / `mcp_audit_logs` triggers are the spine — keep them; add **point-in-time-recovery** backups and a periodic **balanced-journal invariant** job (the invariant tests already encode the rule).
- **DR/backups:** automated PITR on Postgres + Neo4j, cross-region snapshot copies at Stage 1, a documented restore runbook, and quarterly restore drills.
- **Hedera mainnet cutover:** testnet → mainnet with the paymaster HSM/multisig above, plus the reconciliation job in §9 (the deferred on-chain↔ledger invariant `n`).

3 3. The automation fabric — agents, MCP & skills to run the bank

This is the differentiator: **an AI-operated bank** where, per the Phase 15 invariant already designed in `docs/PHASE-15-INTERNAL-AGENT-OPS.md` , **agents decide, deterministic code executes, and humans gate** anything irreversible. The runtime target is already locked: **Temporal** for money-critical workflows, **Conductor (OSS)** for agent orchestration. Build the catalog on the existing seam (`signalService` , `riskOrchestratorService` , `orchestratorModel` , the `agent_runs` table, `tokenFactory` , `rbac`).

Two planes

- **External plane (built — Phase 7):** the **MCP server** lets *third-party* AI agents operate on a user's behalf under user-granted, VP-verified, scope-intersected, 90-second tokens. Already verified end-to-end (scoped-token mint, `SCOPE_DENIED`, balanced-journal transfer, `REPLAY_DETECTED`). This is a moat — keep investing here.
- **Internal plane (Phase 15 design → build):** operating agents that run the bank. Per the security model, internal skills are **read / recommend / draft only** — no agent gets direct money, state, regulator, or infra tools; a deterministic runner executes and a human gates.

Internal operating-agent catalog

Agent	Reads	Produces (draft/recommend)	Human gate
Onboarding risk (exists)	Signals, device/email/IP/behavior	Tier + risk decision rationale	Auto-approve low risk; human on review-required
Compliance triage	Audit logs, sanctions hits, txn patterns	SAR/CTR draft, case summary	Compliance officer files
Dispute / chargeback	Ledger, MCP audit, comms	Resolution recommendation + draft response	Ops approves payout/reversal
Treasury ops	Balances, on-chain + ledger	Rebalance / paymaster top-up proposal	Human signs the multisig
Reconciliation	On-chain state vs ledger	Break report + proposed adjusting entry	Human approves any journal
Support copilot	User state, docs, history	Drafted reply, next- best-action	Agent/human sends

Skills (Claude Agent SDK / MCP tools)

Mirror the repo's own dogfooding pattern — it already ships operational skills (`e2e-validator`, `bankai-mcp-test-harness`) that drive the system as a real client. Extend that idea to **ops skills** (reconciliation report, compliance-case summarizer, incident triage, release validator) so routine operations and CI are agent-automatable, while every state change still flows through the deterministic runner with its audit trail.

Build sequence: Conductor + the runner contract → onboarding-risk (already real) → reconciliation & compliance-triage (highest ops leverage) → treasury & dispute → support copilot.

4. Identity Vault — a Neo4j graph of users & associations

A property graph is the right model for *relationships*, which is exactly where fraud and identity truth live. It complements (does not replace) the Postgres ledger.

Core schema (nodes → relationships):

```
(:User)-[:OWNS]->(:Device)           (:User)-[:USED]->(:IP)
(:User)-[:HOLDS]->(:Credential{VC})  (:User)-[:FUNDS_WITH]->(:Instrument)
(:User)-[:TRANSACTIONED_WITH]->(:User) (:User)-[:NAMES]->(:Beneficiary)
(:User)-[:SHARES]->(:Attribute)      (:Wallet)-[:BOUND_TO]->(:DidKey)
```

Fed from what already exists — no new capture layer:

- onboarding **signals** (device fingerprint, email/IP/behavior scores) → device/IP/attribute edges;
- the **ledger** → **TRANSACTIONED_WITH** edges with weights;
- **MCP audit logs** + VP/holder-binding → wallet↔DID↔credential edges;
- KYC/VC issuance → credential and shared-attribute edges.

What it unlocks: synthetic-identity rings (many users → one device/instrument), shared-device and shared-beneficiary fraud, collusion clusters, and "who is this account actually connected to" for compliance. Graph features (community, centrality, shortest-path-to-known-bad) feed the fraud model in §5.

Hosting & guardrails: Neo4j Aura (managed) at Stage 0/1 — don't self-host a database you'll stake fraud decisions on. Treat it as **PII**: field-level encryption for identifiers, strict access control, a documented **retention/erasure** policy (GDPR/CCPA right-to-delete must cascade), and **no raw PII in graph properties** you don't need — store hashes/refs where possible.

5 5. Fraud detection — best-of-breed, built on your orchestration engine

The brief is right: **capture every good transaction and signal across the entire user lifecycle**, and learn normal so anomalies stand out. Build it *on top of the orchestration engine already in the product*, not as a bolt-on.

Pipeline:

1. **Capture (lifecycle-wide)**: every onboarding signal, login, device, ledger journal, MCP call, marketplace action → an event stream. The append-only audit/ledger tables are the durable spine; add a streaming tap (Redis/Kafka-lite) for real-time.
2. **Feature store**: rolling user/device/graph features (velocity, novelty, peer-comparison, the Neo4j graph features from §4). Online (low-latency) + offline (training) views.
3. **Scoring (layered)**:
 - **Rules** (deterministic, explainable) — velocity caps, sanctions, impossible-travel, the existing >\$500 MFA gate and per-agent rate limits;
 - **ML anomaly** — unsupervised baseline (isolation forest / autoencoder) for "this is weird," plus a supervised model as labels accumulate;
 - **Graph signals** — proximity to known-bad clusters.
4. **Inline decision**: score **synchronously** on the money path (the ledger/MCP transfer flow already mints short-lived tokens and posts balanced journals — the natural choke point). Allow / step-up (MFA) / hold / block, each an auditable event.
5. **Feedback loop**: confirmed fraud/good labels flow back into the Identity Vault and retrain — the lifecycle-learning the brief describes.

Build vs buy: build the orchestration + rules + graph layer in-house (it's your moat and it sits on infra you own), and buy the model/monitoring layer if speed matters — **Unit21** or **Hawk AI** (AML/txn monitoring with case management) or **Sift** (consumer fraud).

Recommendation: in-house rules+graph from day one; add a vendor for AML case management at Phase B when the regulator expects it; keep the ML model in **Vertex AI/SageMaker** so you own the IP.

6. Constellation Network "Digital Evidence" — a later-phase evaluation

What it is: Constellation's Hypergraph / Digital Evidence lets you notarize data and produce tamper-evident, independently-verifiable attestations of records and their lineage.

Where it could fit: as an *external anchor* over your already-append-only `audit_logs` / `mcp_audit_logs` / ledger — periodically committing cryptographic proofs so a regulator or counterparty can verify the audit trail wasn't altered, without trusting your database. It pairs naturally with the VC/DID evidence the product already issues.

Pros	Cons
Independent, tamper-evident compliance attestations	Adds a vendor + chain dependency
Strengthens regulator/auditor trust story	Your DB triggers already give strong internal immutability
Aligns with the DID/VC, on-chain ethos	Unproven ROI until a regulator/partner asks for it

Recommendation: defer to Phase B/C (post-launch). Internal append-only triggers + KMS + good backups are sufficient for launch. Revisit Constellation when a **partner bank, auditor, or regulator** specifically wants third-party-verifiable evidence — then it's a differentiator, not overhead. Track it; don't build it into v1.

7. Mobile — launch iOS first

Recommendation: iOS first, Android fast-follow.

- The repo's **SwiftUI wallet (Phase 10)** is already the furthest-along native surface (Secure-Enclave P-256 signing key, VC-in-Keychain, `did:key` encoder matching the backend, OID4VP/OID4VCI deep links) — less new work to ship.
- **Secure Enclave** is the cleanest expression of the locked non-custodial key model and the passkey-first story; Android Keystore is equivalent but you've already invested in the iOS path.
- US-first demographics + higher iOS engagement/ARPU + App Store trust suit a finance app's first cohort.

- App Store review for crypto/finance is strict but predictable; lead with the non-custodial, no-customer-funds (Phase A) framing.

Then Android: the architecture is explicitly "native build, keys in Secure Enclave / **Android Keystore**" — the second platform is a known, planned port, not a redesign. (Note the documented gap: the iOS source is reviewed-but-unverified — it needs an Xcode build/sign/submit pass before any store submission.)

8 8. Marketing & go-to-market

Positioning (and the legal guardrail): you are an **AI-operated, tokenization-first money app** — **not** "a bank." Honor the Corporate-doc naming rule: never imply you hold deposits or are chartered. Lead with the wedge that's actually novel: **AI agents that act on your money under cryptographic, user-granted permission, and tokenized real-world assets** you can hold in a non-custodial wallet.

- **Wedge:** the agent + MCP experience (let your AI assistant check balances, move money, and trade under scoped, revocable, audited permission) is a genuinely differentiated story in 2026.
 - **Early segment:** crypto-comfortable, AI-forward early adopters and RWA-curious investors — not the mass market. Invite-only **waitlist** with referral mechanics to manufacture scarcity and control onboarding risk.
 - **Compliance-safe messaging:** "tokenized assets," "non-custodial wallet," "agentic finance" — never "deposits," "FDIC," "bank account," or investment-return promises. Every investment surface carries the "not advice / not an offering" disclaimer the product already models.
 - **Content & community:** build in public on the agent/MCP + DID/VC tech; developer-credible content earns the early crypto/AI crowd. Position the MCP server as a platform third parties can build on.
 - **Narrative:** "the first bank run by AI agents — that you actually control." Differentiation, not feature parity.
-

9. Tech gaps to close (additive checklist)

#	Gap	Priority	Note
1	KMS / HSM for server-held keys	⚠ Stage 1	The documented <code>private_key_hex</code> gap; treasury multisig
2	On-chain ↔ ledger reconciliation	Stage 1	The deferred invariant <code>n</code> ; powers the reconciliation agent (§3)
3	Data warehouse + analytics	Stage 1	BigQuery/Redshift; product + risk analytics
4	Feature store	Stage 1	Underpins \$5 fraud ML (Feast or managed)
5	Model registry + monitoring	Stage 1	Versioning, drift, explainability for fraud models
6	Incident response + on-call	Stage 0→1	Runbooks, paging, status comms
7	SOC 2 readiness automation	Phase B	Vanta/Drata; partners will require SOC 2 Type II
8	Public status page	Stage 0	Trust signal; ~free
9	WAF / DDoS / bot defense	Stage 0	Cloudflare in front (already in the stack)
10	Secrets rotation + key ceremony	Stage 1	Especially the Hedera treasury keys
11	Dedicated staging env	Stage 0	Mirror of prod; the E2E suite already targets it
12	Rate-limit hardening at the edge	Stage 0	The app limiter exists; add edge limits too
13	Backup restore drills	Stage 1	Test DR quarterly, not just configure it

10. Phased production roadmap (aligned to the compliance ramp)

Compliance phase (Corp doc)	A (non-custodial)	B (partnered, MSB)	C (own licenses)
Cloud	Render/Fly + Neon + Aura	AWS (or GCP) single VPC	Multi-AZ HA, audited
Keys	On-device + Infisical	KMS/HSM + treasury multisig	HSM key ceremonies
Agents	Onboarding-risk live; MCP external	+ reconciliation, compliance-triage, treasury	Full AI-ops with regulator-grade audit
Fraud	Rules + graph (in-house)	+ ML anomaly + AML vendor	Tuned models + case management
Identity Vault	Neo4j Aura, core schema	Graph features into fraud model	Regulator-facing link analysis
Mobile	ios (verify Xcode build)	+ Android	Both, hardened
Evidence	Append-only triggers + KMS	Evaluate Constellation	Constellation if a partner needs it
Compliance tooling	ToS/AML policy + OFAC	SOC 2 (Vanta/Drata)	Exams, MTL/transfer-agent

The throughline: every stage spends only what the prior stage's traction earns. You launch on ~\$100/mo of PaaS as a non-custodial software product; you bring KMS, ML fraud, a second mobile platform, and SOC 2 only when partners and scale require them; and you reserve the expensive hyperscaler + licensing posture for when revenue justifies it — the same lean-now / hardened-later logic that drives the corporate structure.

Companion document: Corporate Structure & Compliance Strategy (the lean Wyoming-LLC → Delaware-C-corp path and the Phase A/B/C compliance ramp this roadmap aligns to).